Fundamentals of Cloud Identity, Security, and Compliance

An INE On-Demand Course

Part of the INE Cloud Foundations Series

Tracy Wallace

Azure Solutions Architect Expert

twallace@ine.com

@TracyWallaceTec

linkedin.com/in/tracy-wallace-746482a

Fundamentals of Cloud Identity, Security, and Compliance

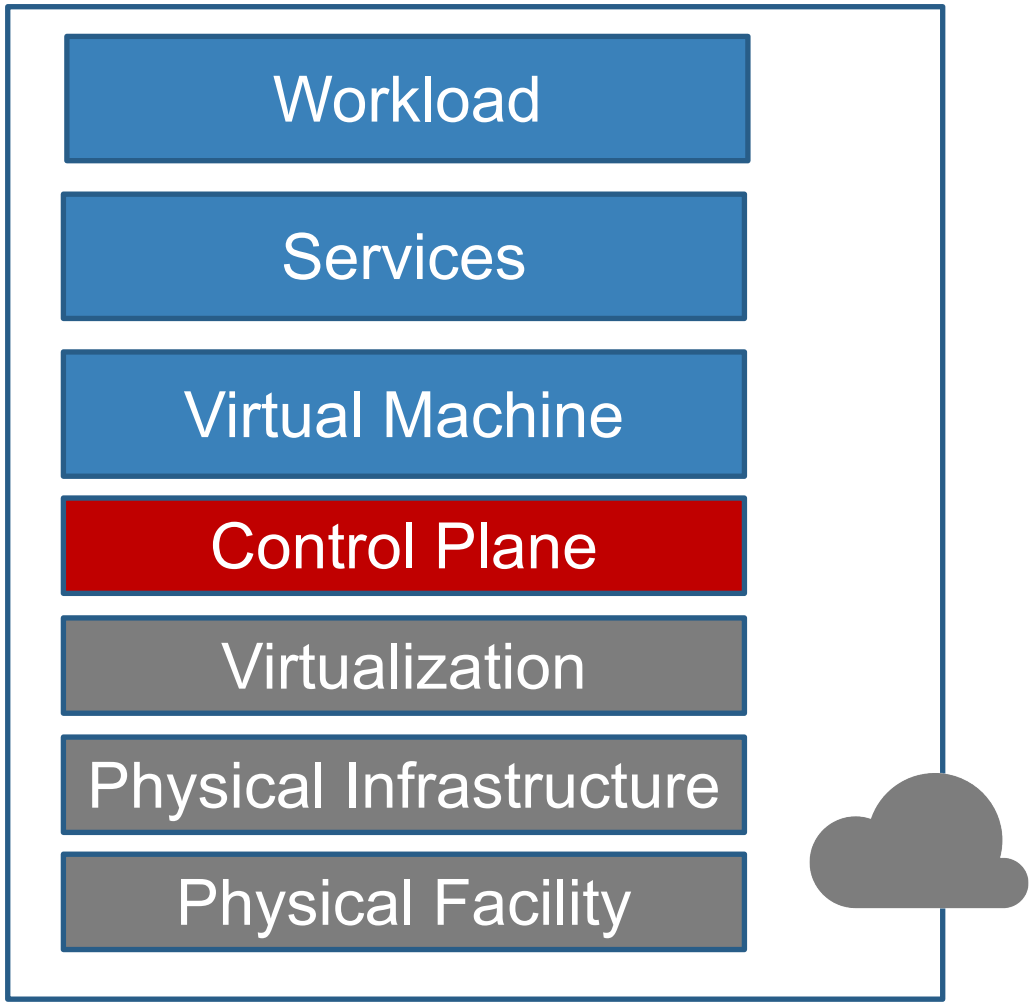
+ Fundamentals of Cloud Security
+ Common Cloud Attacks
+ Identity Protection
+ Resource Protection
+ Regulatory Compliance in the Cloud

Fundamentals of Cloud Security

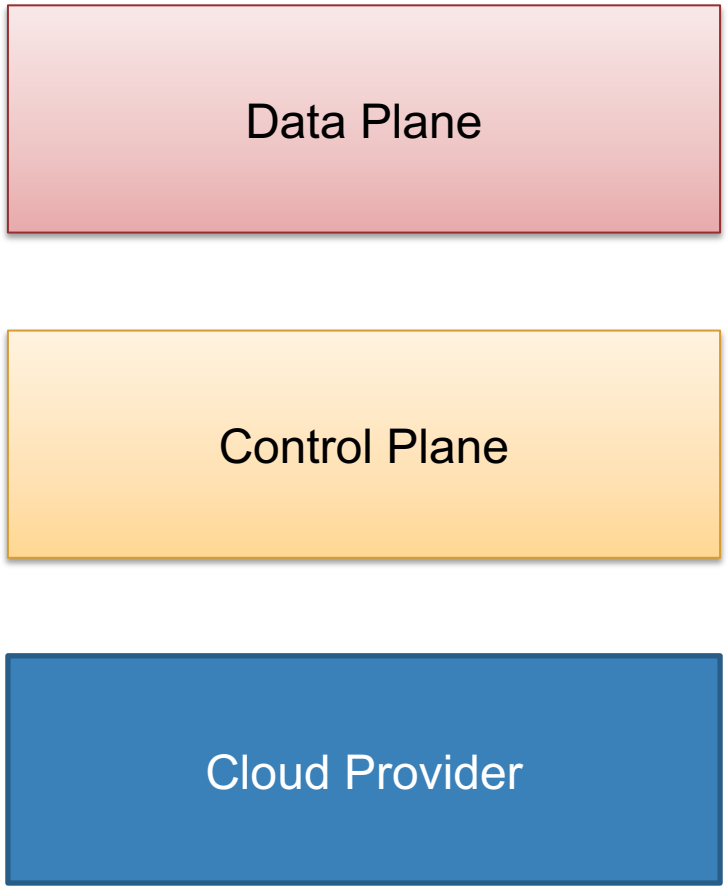
Fundamentals of Cloud Security

- Shared Responsibility Model
- Securing Cloud Resources
- Defense in Depth

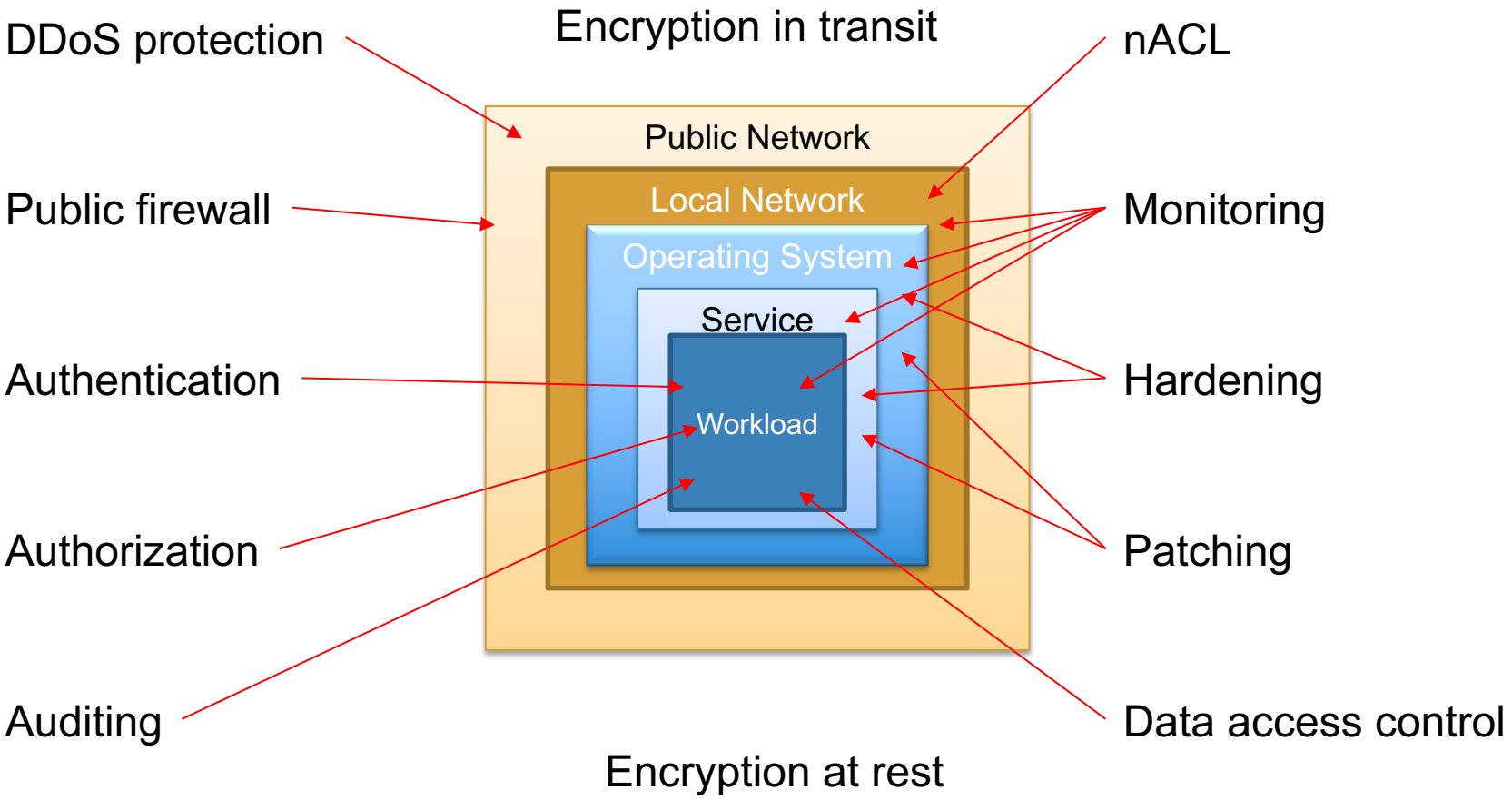
Shared Responsibility Model



Securing Cloud Resources



Defense in Depth



Common Cloud Attacks

Common Cloud Attacks

- Attack Targets
- Attack Methods

Identities
Data
Services

Attack Targets

- Software as a Service (SaaS) identities
- Cloud platform identities
- Data plane identities

Attack Targets

Identities
Data
Services

Attack Targets

Identities
Data
Services

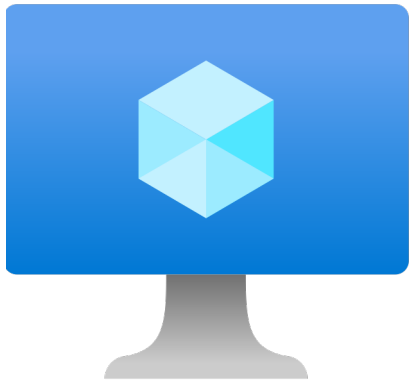


Photo by Unknown Author is licensed under CC BY-SA

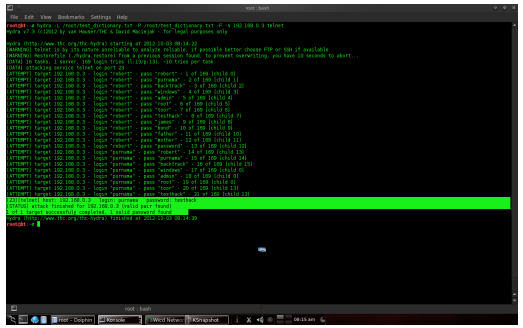
Attack Methods

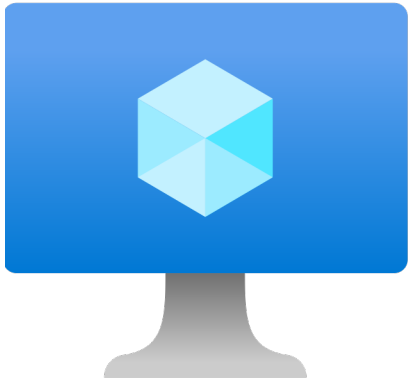
Misconfiguration
Account Hijacking
Service Hijacking
Malware

- Intentional or inadvertent
- Data stores or services
  - Database
  - Public API
  - Service
- Allows unauthorized third-party access

Attack Methods

Misconfiguration
Account Hijacking
Service Hijacking
Malware





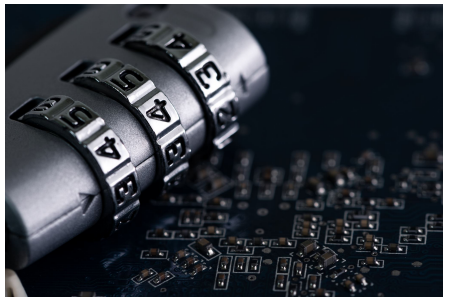


Photo by Unknown Author is licensed under CC BY-SA

Attack Methods

Misconfiguration
Account Hijacking
Service Hijacking
Malware

Attack Methods

Misconfiguration
Account Hijacking
Service Hijacking
Malware

Identity and Access Management

Identity and Access Management

- Accessing and Managing Cloud Resources
- Managing Cloud Users
- Managing Access to Resources
- Demo: Managing Cloud Users

Accessing and Managing Cloud Resources

Managing Cloud Users

- Minimize "root" user access
- Organize into groups
- Use dynamic management when possible
- Audit and review user configuration

Managing Access to Resources

- Always apply least privilege
- Use dynamic access policies when possible
- Audit resource access
- Separate control plane and data plane access

Demo: Managing Cloud Users

Identity Protection

Identity Protection

- Cloud Identity Sources
- Identity Vulnerabilities
- Managing Identities
- Identity Protection Services
- Identity Best Practices

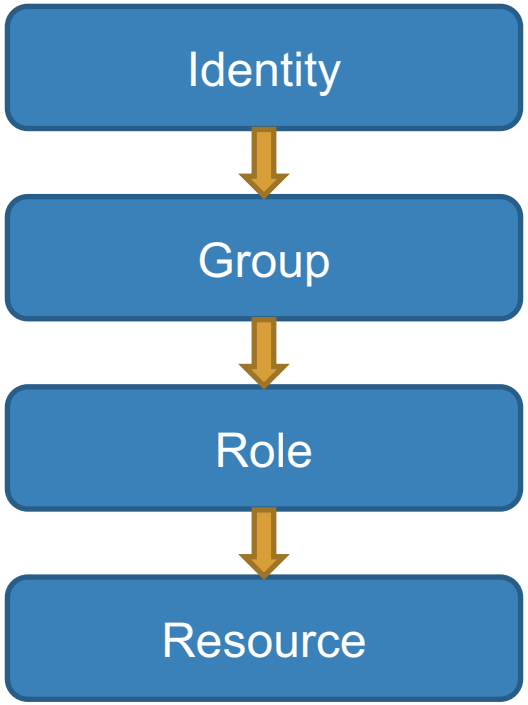
Cloud Identity Sources

Identity Vulnerabilities

Account Vulnerabilities	Login Vulnerabilities
Weak passwords Leaked credentials General threat intelligence	IP Address and location anomalies Password spraying Brute force attacks

Managing Identities

Privileged access



Password management

Dynamic access management

Rights management

Managing Identities

AWS	Azure	GCP
IAM Users IAM Roles IAM Policies	Azure AD Users Azure AD Service Principals Azure AD Managed Identities Roles	Google Account Service Account Role Policy

Identity Protection Services

AWS	Azure	GCP
CloudTrail Trusted Advisor	Identity Protection Azure AD Logs	Advanced Protection Program G-suite alert center Titan security keys

Multi-Factor Authentication

Identity Best Practices

- Apply password policy
- Implement conditional access
- Implement MFA
- Monitor
- Audit unused accounts

Responding to Identity Compromise

Responding to Identity Compromise

- The Five R’s
- The Response Process

The Five R's

Revoke

Reset

Review

Remediate

Return

The Response Process

Revoke
Reset
Review
Remediate
Return

- Revoke permissions for the compromised identity
- Isolate the identity from data services, and resources

The Response Process

Revoke
Reset
Review
Remediate
Return

- Session tokens
- API keys
- Resource access keys
- Any form of trusted identity

The Response Process

Revoke
Reset
Review
Remediate
Return

- Review with IT
- Review with business personnel
- Determine impact

The Response Process

Revoke
Reset
Review
Remediate
Return

- Remedial training
- Improve processes
- Define forward plan of action
- Report as necessary

The Response Process

Revoke
Reset
Review
Remediate
Return

- Return to operating state
- Monitor

Data Protection

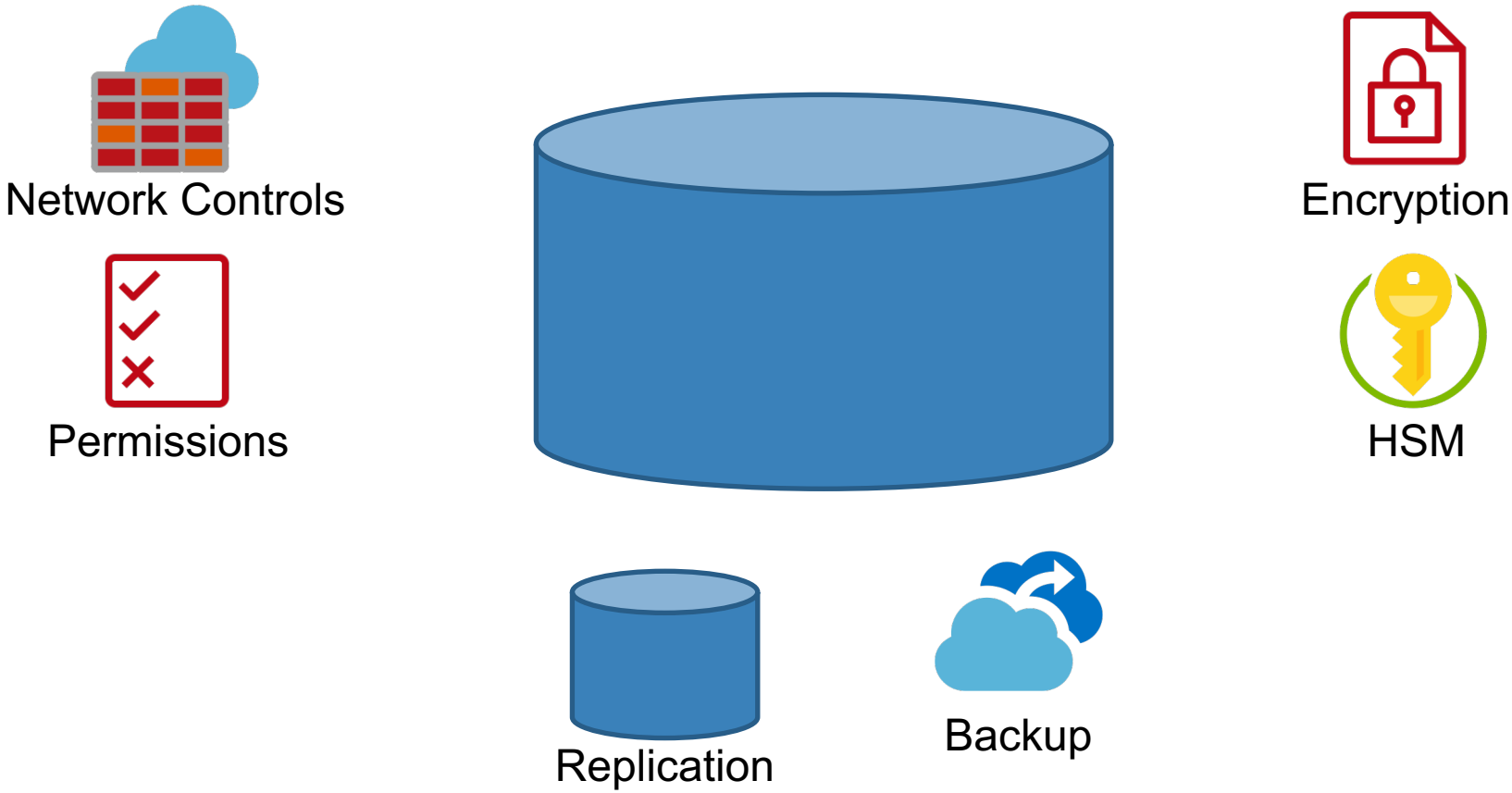
Data Protection

- Types of Cloud Data
- Protecting Data at Rest
- Protecting Data in Transit
- Connecting to Data
- Demo: Data Encryption
- Data Protection Best Practices

Types of Cloud Data

Files	Relational	Non-relational	Big data	Sensitive
Blobs Buckets File services	Managed Proprietary IaaS hosted	Managed Proprietary IaaS hosted	Semi-structured	Keys Certificates Audit

Protecting Data at Rest



Protecting Data in Transit

Encrypt
Your
Data
In
Transit

Connecting to Data

Demo: Data Encryption

Data Protection Best Practices

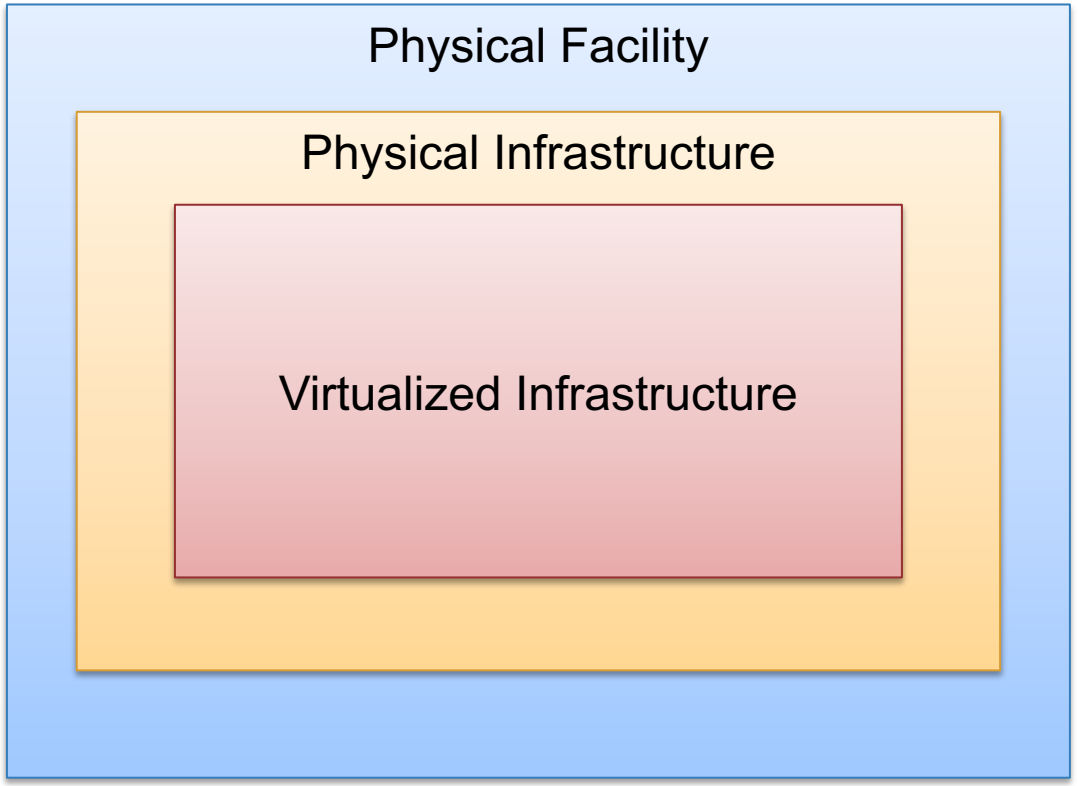
- Limit access
  - Resource
  - Data
  - Network
- Always encrypt
  - At rest
  - In transit
  - End-to-end
- Protect from failure
  - Replicate
  - Backup
- Audit

Network Protection

Network Protection

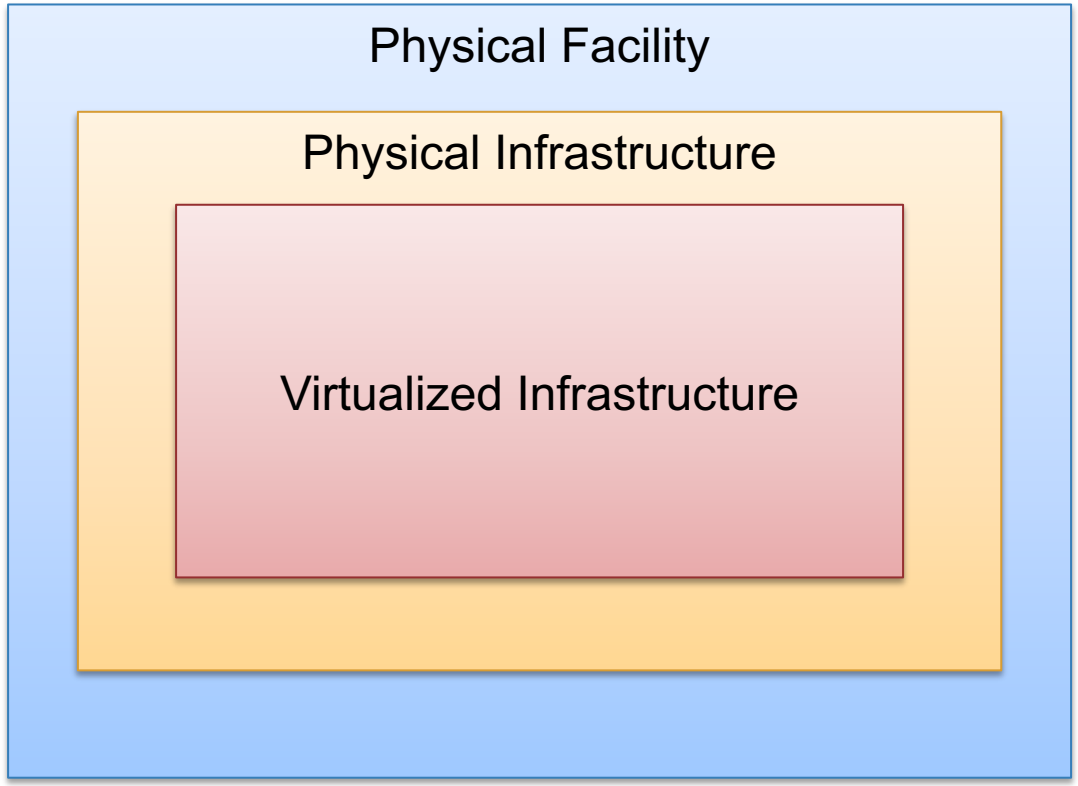
- Cloud Provider Network Protection
- Tenant Network Protection
- Cloud Network Controls
- Demo: Controlling Network Access
- Network Protection Best Practices

Cloud Provider Network Protection



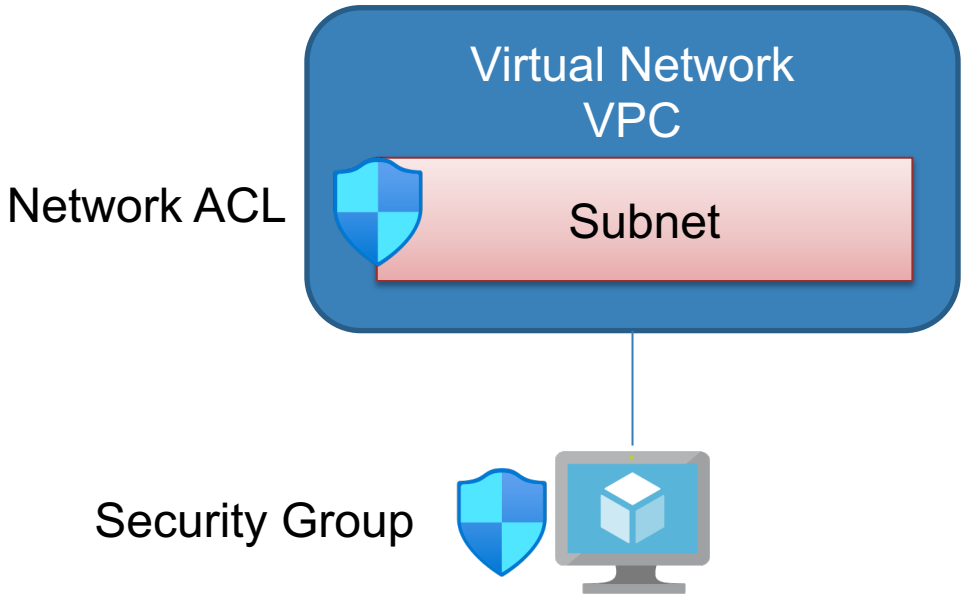
Cloud Provider Network Protection

DDoS protection
General threat protection



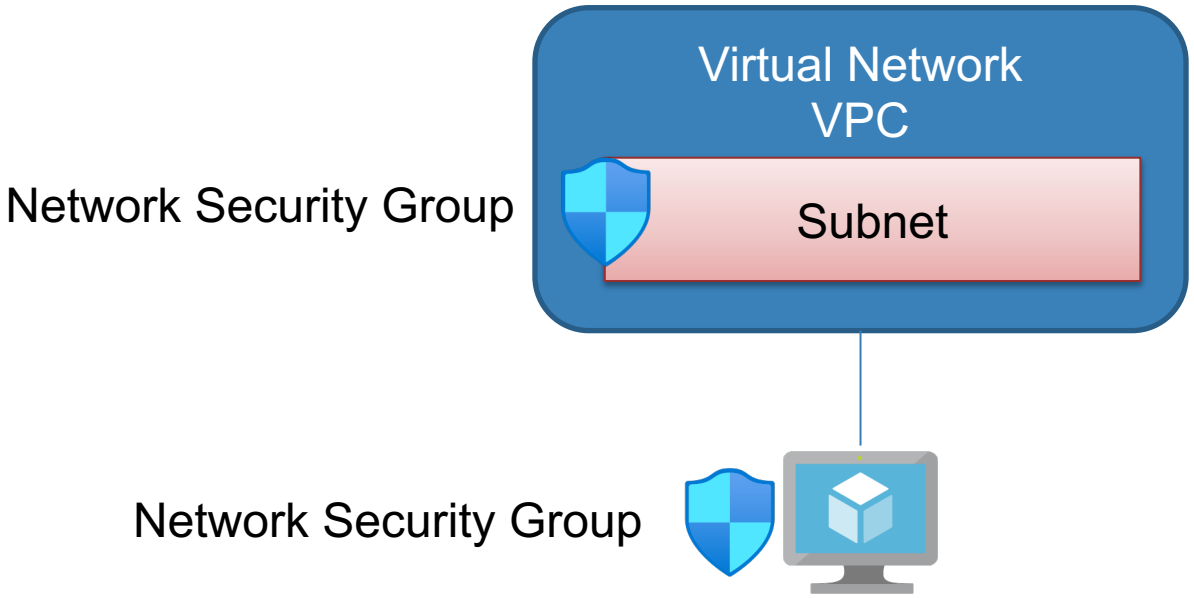
Tenant Network Protection

AWS



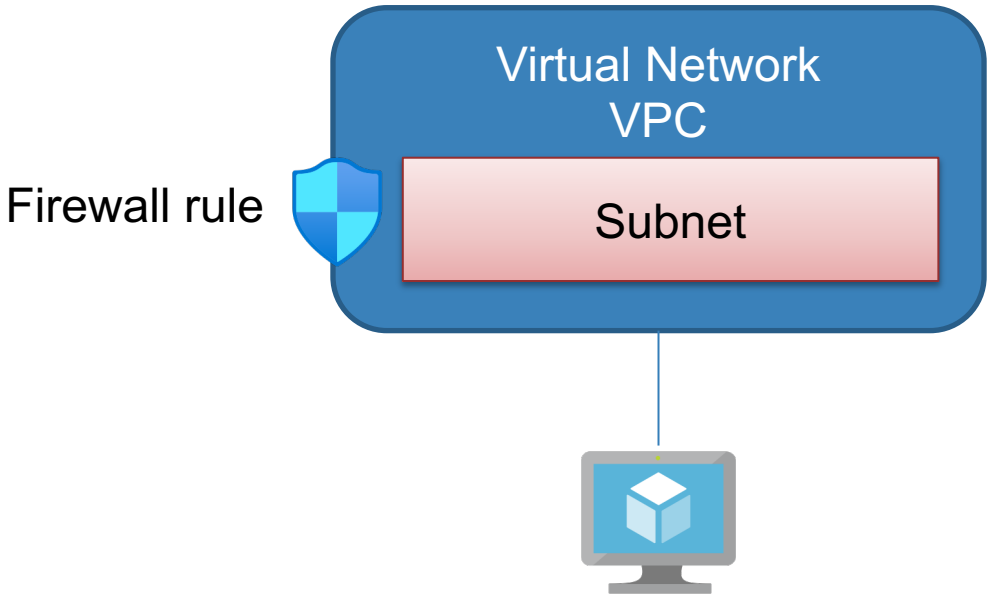
Tenant Network Protection

Azure



Tenant Network Protection

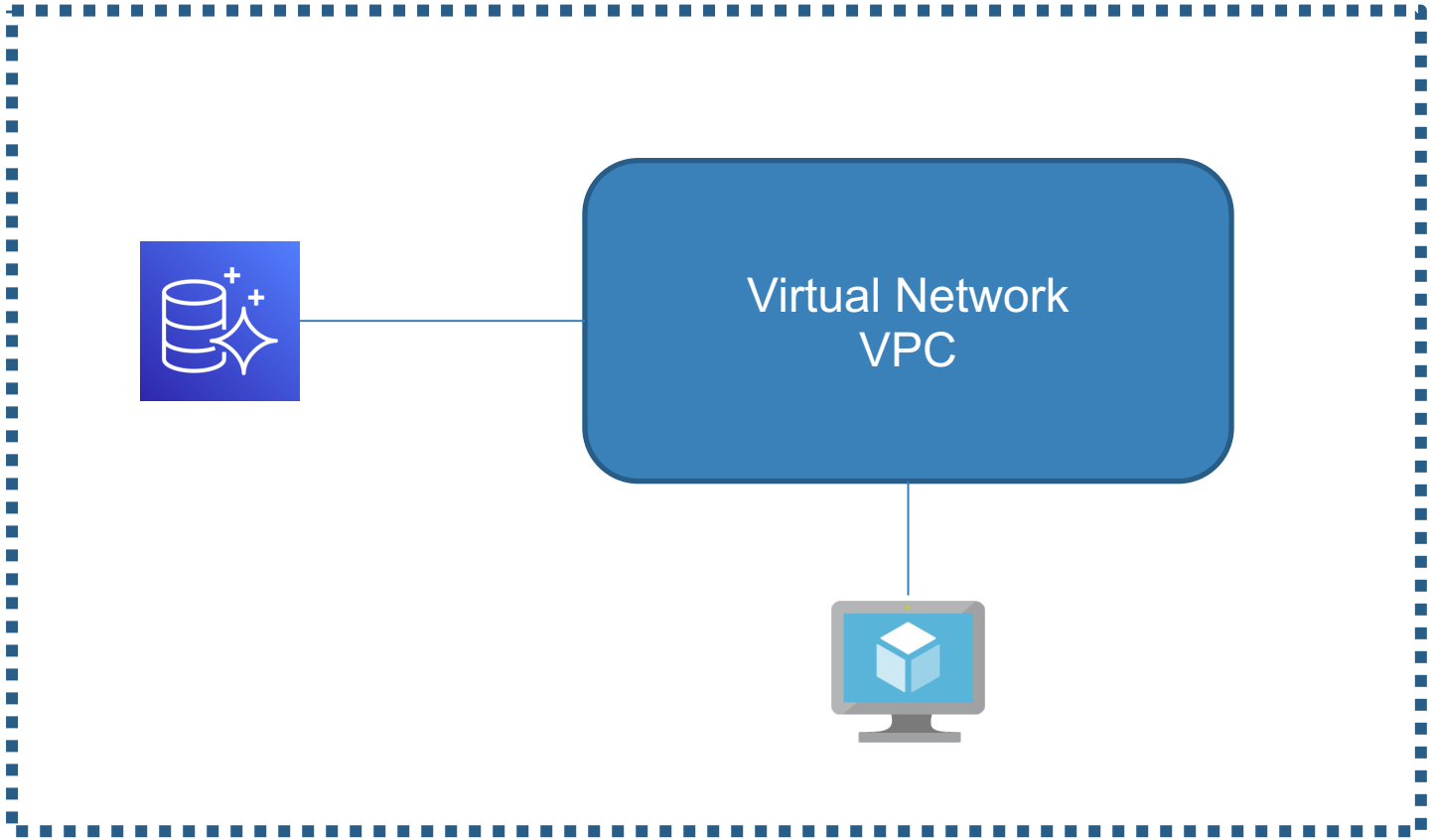
GCP



Tenant Network Protection

Tenant Network Protection

GCP – VPC Service Control
Azure – Private Endpoint
AWS - PrivateLink



Network Security Services

AWS	Azure	GCP
AWS Shield AWS WAF AWS GuardDuty	Azure Firewall Application Gateway Azure FrontDoor	Google Cloud Armor

Demo: Controlling Network Access

Network Protection Best Practices

- Leverage provider tools
- Limit public attack surface
- Monitor
- Alert atypical usage patterns
- Have a playbook

Compute Protection

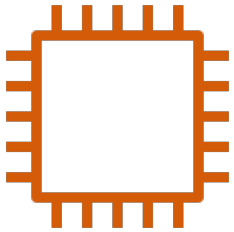
Compute Protection

- Infrastructure Compute Protection
- Platform Compute Protection
- Patching
- Confidential Compute
- Compute Monitoring

Infrastructure Compute Protection

Patch management

Resource protection



OS hardening

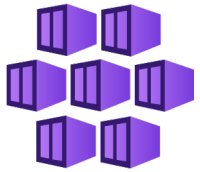
Attack surface minimization

Monitoring

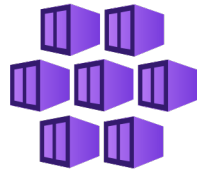
Infrastructure Compute Protection

Multiple instances

Platform Compute Protection



Platform Compute Protection

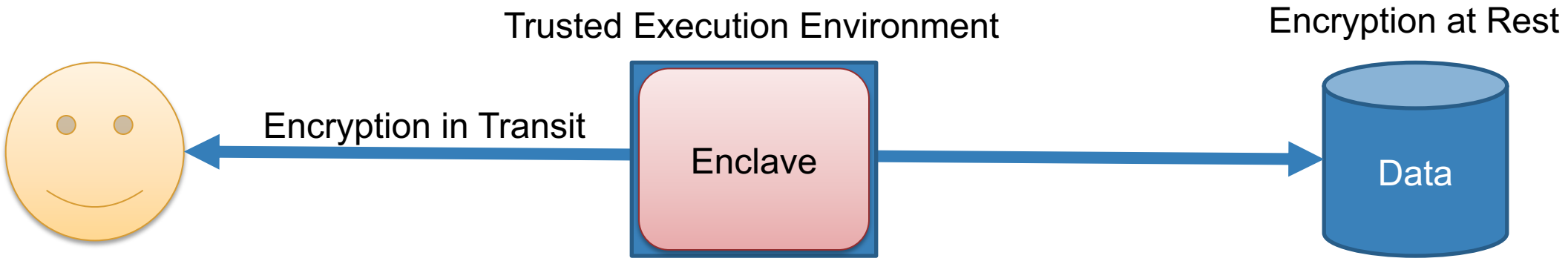


Patching

- Infrastructure as a Service
  - OS – automated option in AWS and Azure
  - Service (such as web server or database server)
- Platform as a Service
  - Always patched by the provider

Confidential Compute

Confidential Compute

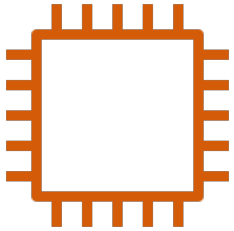


Protects against:

- Unauthorized data access
- Code corruption

Available on specific compute instance sizes

Compute Monitoring

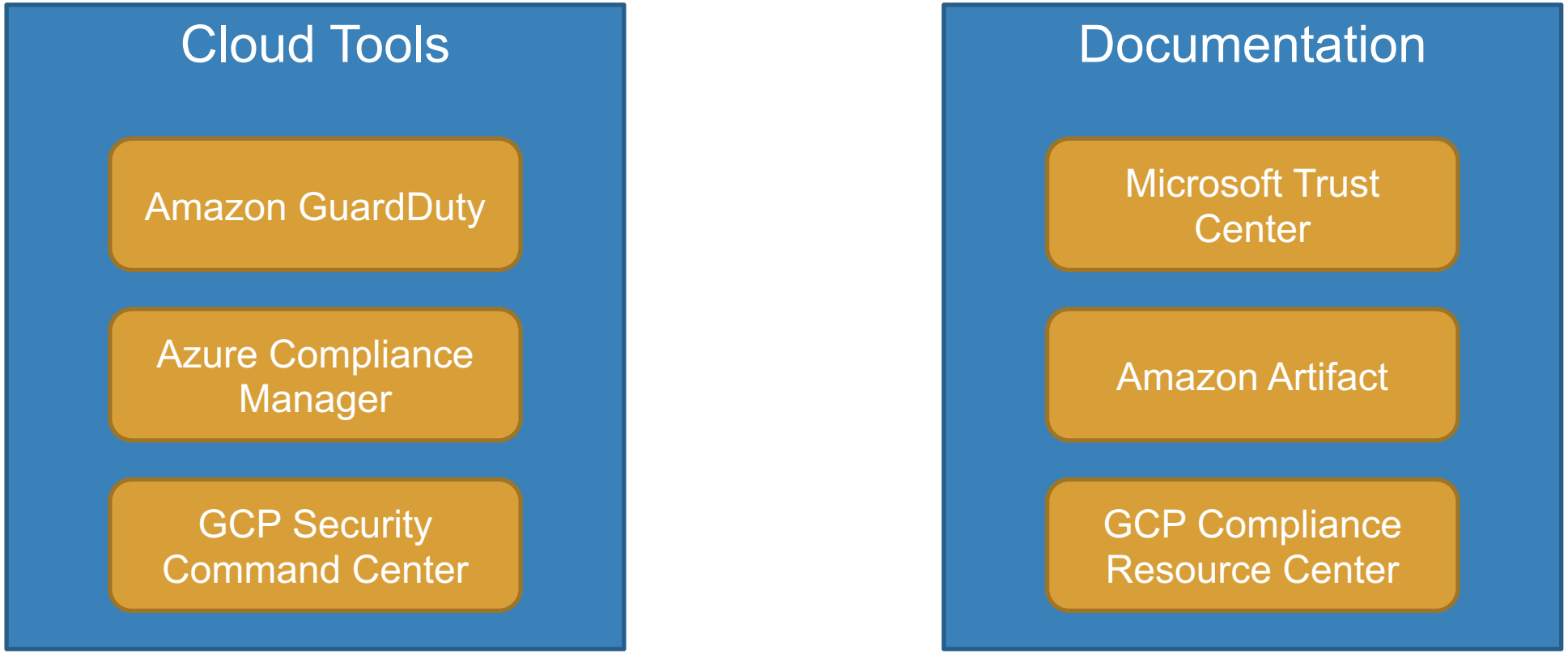


Regulatory Compliance in the Cloud

Regulatory Compliance in the Cloud

- Cloud Provider Regulatory Support
- Tenant Responsibilities
- Common Protected Data
- Demo: Provider Regulatory Support

Cloud Provider Regulatory Support



Tenant Responsibilities

- Understand your regulatory requirements
- Document provider compliance with regulations
- Implement your responsibilities
- Use the provider tools to achieve, maintain, and document compliance

Common Protected Data

- Types of Data
  - Personal Identifiable Information (PII)
  - Health Care (Protected Health Information)
  - Financial Services (PII, PCI-DSS, Sarbanes Oxley)
- Business Relevance
  - Intellectual Property
  - Legal Considerations
  - Business Reputation
- Regional Considerations
  - GDPR-EU
  - California
  - US Federal Protected Data Type (research, technology, weapon, etc.)

Demo: Provider Regulatory Support

Fundamentals of Cloud Identity, Security, and Compliance

An INE On-Demand Course

Part of the INE Cloud Foundations Series

Fundamentals of Cloud Identity, Security, and Compliance

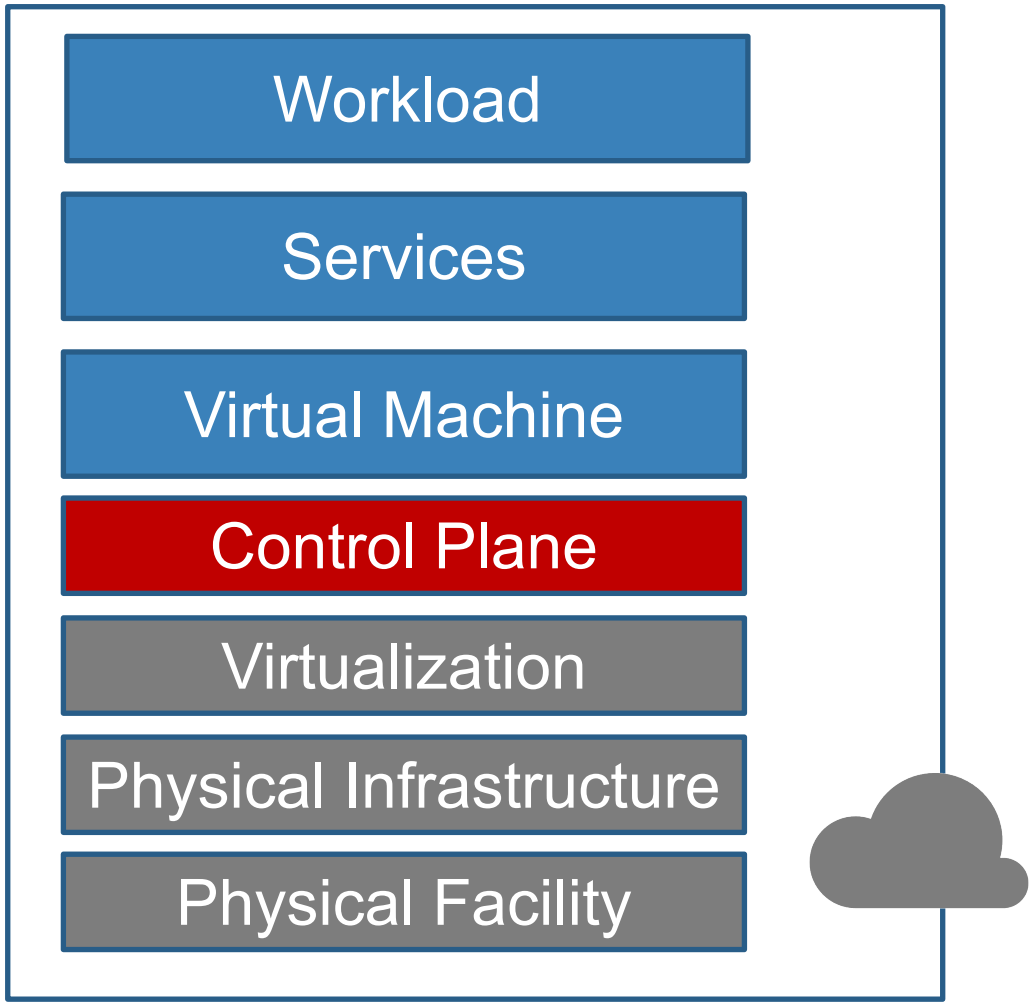
+ Fundamentals of Cloud Security
+ Common Cloud Attacks
+ Identity Protection
+ Resource Protection
+ Regulatory Compliance in the Cloud

Fundamentals of Cloud Identity, Security, and Compliance

An INE On-Demand Course

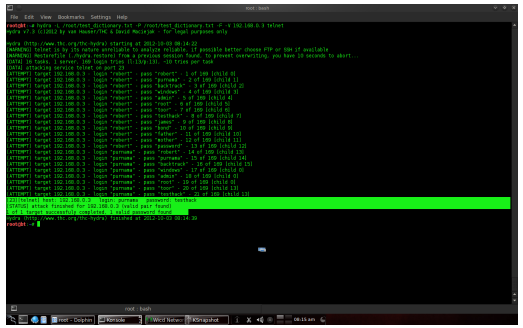
Part of the INE Cloud Foundations Series

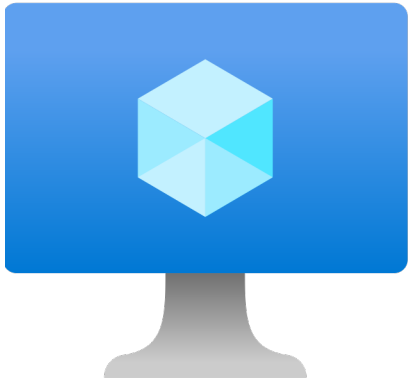
Shared Responsibility Model



Attack Methods

Misconfiguration
Account Hijacking
Service Hijacking
Malware





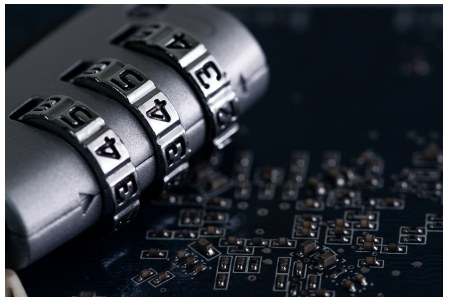


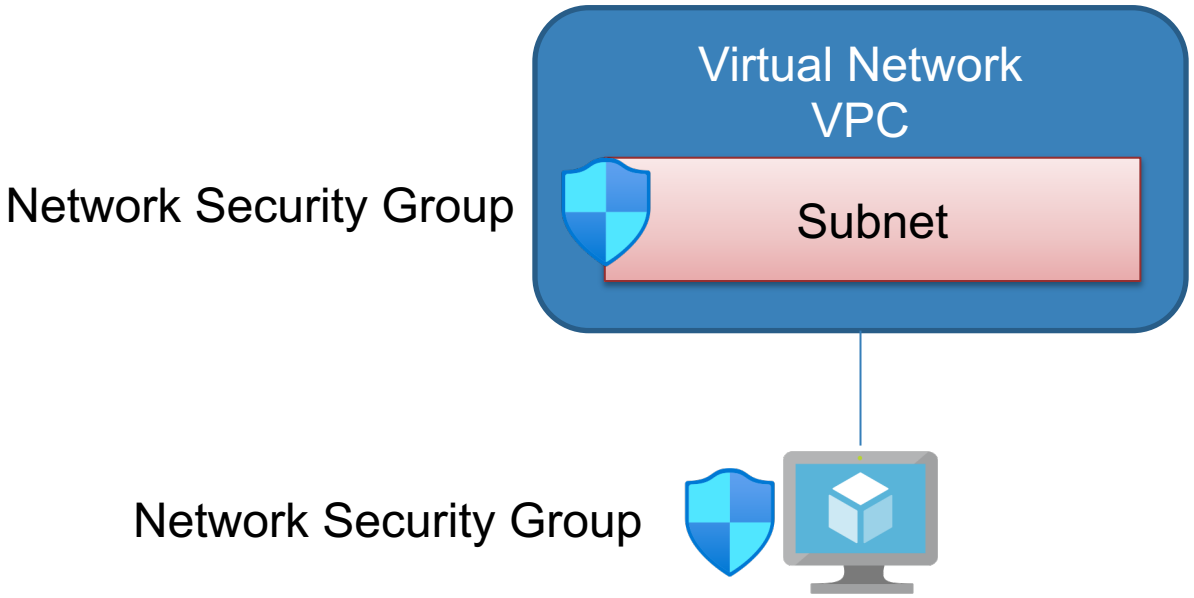
Photo by Unknown Author is licensed under CC BY-SA

Identity Vulnerabilities

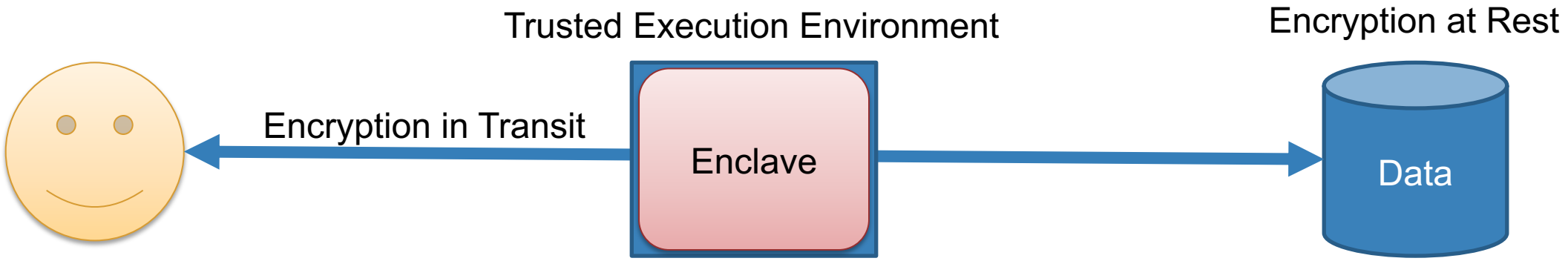
Account Vulnerabilities	Login Vulnerabilities
Weak passwords Leaked credentials General threat intelligence	IP Address and location anomalies Password spraying Brute force attacks

Tenant Network Protection

Azure



Confidential Compute



Protects against:

- Unauthorized data access
- Code corruption

Available on specific compute instance sizes

Cloud Provider Regulatory Support